MSM ACADEMY

SECTION 5

ISMS
Gap analysis



5.1 What a gap analysis is
5.2 Gap analysis versus internal audit
5.3 Planning and conducting a gap analysis
5.4 The MSM gap analysis tool
5.5 From findings to an implementation plan
5.6 Tracking progress

MSM ACADEMY

SECTION 5 · LESSON 5.1

What a gap analysis is

Definition, purpose and timing

5.1

LESSON 5.1

Definition and purpose

A structured comparison

- Current practice compared with every requirement of the standard
- And with the Annex A controls the organization is likely to need
- Result: what is in place, what is partial, what is missing

LESSON 5.1

Why it matters

Four things a gap analysis gives you

1. A realistic view of readiness, before anyone commits to a date
2. Priorities: what to fix first, and what can wait
3. A basis for estimating effort, resources and cost
4. A baseline to measure implementation progress against

LESSON 5.1

When to run one

Four common moments

- Before implementing an ISMS
- When the scope changes, for example after an acquisition
- When integrating with other management systems
- When the standard changes, for example Amendment 1:2024

LESSON 5.1

A gap is not a nonconformity

Use the right word for the right thing

- Before implementation, there is no ISMS that can fail to conform
- A gap is a requirement not yet met by the organization’s practice
- Rate gaps by implementation status: Comply, Partially implemented, Not implemented

Gap analysis: two perspectives

Implementer's view

- Use it to set the baseline and the plan
- Rate by implementation status
- Repeat it when scope or the standard changes

Auditor's view

- A gap analysis is not evidence of conformity
- Expect it to have driven the plan
- Look for the baseline behind progress claims

LESSON 5.1 · RECAP

Lesson 5.1 recap

- A structured comparison with every requirement and likely controls
- Gives readiness, priorities, estimates and a baseline
- Run it before implementation, on scope change, integration or a revised standard
- Findings are gaps, rated by implementation status

Check your understanding

Before any ISMS exists, a consultant’s report lists “27 nonconformities”. What is the main issue?

A None: any unmet requirement is a nonconformity

B The findings are gaps; a nonconformity needs a system meant to be meeting the requirement

C Gap analyses may not report findings

D 27 is too many for a first report

Check your understanding

Before any ISMS exists, a consultant’s report lists “27 nonconformities”. What is the main issue?

A. None: any unmet requirement is a nonconformity

B. The findings are gaps; a nonconformity needs a system meant to be meeting the requirement

C. Gap analyses may not report findings

D. 27 is too many for a first report

Answer: B

Before implementation, unmet requirements are gaps. Nonconformity describes a system that should be meeting a requirement and is not.

MSM ACADEMY

SECTION 5 · LESSON 5.2

Gap analysis versus internal audit

5.2

Two different tools

LESSON 5.2

Two different tools (1 of 2)

Aspect	Gap analysis	Internal audit (9.2)
Purpose	How far current practice is from the requirements	Whether the ISMS conforms and is effectively implemented
Timing	Before or early in implementation; on major change	At planned intervals, once the ISMS operates
Focus	What is in place, partial or missing	Evidence that processes run and achieve results
Output	Rated gaps and a remedial plan	Audit findings, including nonconformities and OFIs

LESSON 5.2

Two different tools (2 of 2)

Aspect	Gap analysis	Internal audit (9.2)
Who	Implementer, consultant or project team	Objective, impartial auditors
Follow-up	Remedial actions in the implementation plan	Corrective action for nonconformities (10.2)
Formality	Structured, but set by the project	Planned programme, defined criteria and scope, reported results
Frequency	Once, then repeated on major change	Recurring, per the audit programme

LESSON 5.2

Why a gap analysis cannot replace an internal audit

Clause 9.2 asks for more

- A planned programme, considering importance and previous results
- Defined criteria and scope for each audit
- Objective, impartial auditors, and results reported to management

LESSON 5.2 · RECAP

Lesson 5.2 recap

- Gap analysis: how far practice is from the requirements
- Internal audit: whether an operating ISMS conforms and works
- Gaps get remedial actions; nonconformities get corrective action
- A gap analysis cannot stand in for clause 9.2

Check your understanding

Two months before certification, a company says its gap analysis from last year “is our internal audit”. Which response is best?

A Accept it: any structured assessment counts

B Accept it if the gap analysis was very detailed

C Accept it if the consultant signs it as an audit

D Not sufficient: 9.2 needs a planned programme, objective auditors and reported results

Check your understanding

Two months before certification, a company says its gap analysis from last year “is our internal audit”. Which response is best?

A. Accept it: any structured assessment counts

B. Accept it if the gap analysis was very detailed

C. Accept it if the consultant signs it as an audit

D. Not sufficient: 9.2 needs a planned programme, objective auditors and reported results

Answer: D

Clause 9.2 requires a planned programme, defined criteria and scope, objective and impartial auditors, and reported results. A past gap analysis does not provide these.

MSM ACADEMY

SECTION 5 · LESSON 5.3

Planning and conducting a gap analysis

5.3

Evidence before ratings

Five steps

1	**Scope**	Agree the ISMS scope and the criteria: the standard and likely controls
2	**Plan**	Choose who to interview, what to read, what to observe
3	**Collect**	Gather evidence from interviews, documents and sampling
4	**Rate**	Rate each item against the evidence
5	**Report**	Report findings and turn them into a plan

LESSON 5.3

Sources of evidence

Use all three, and compare them

- Interviews: how work is really done, and who decides
- Documents and records: what exists, who owns it, how current it is
- Observation and sampling: whether practice matches what people say

LESSON 5.3

Planning interviews

Who, in what order, about what

- Start with leadership for context, then owners of each process
- Prepare open questions from the checklist, not the checklist itself
- Ask to be shown: “Could you walk me through the last one?”

LESSON 5.3

Recording evidence

Facts, not impressions

- What was seen or heard, where, and from whom
- Document names, versions, dates and sample references
- The rating follows from the record, never the other way round

Role play: the gap interview



Claire Dubois HR Director

“Screening, contracts, leavers: we do all of that already. Every new employee is checked and signs a confidentiality clause.”

YOU

Your move: Turn “we do all of that” into evidence, without challenging her. What do you ask?

LESSON 5.3 · ROLE PLAY

One way to ask it

“That’s helpful. Could you walk me through the last two people who joined, and one who left? And how does it work for contract developers?”

Why it works

- Thanks her, and believes her first
- Asks to be shown real cases, not described ones
- Opens the next question naturally: contractors and leavers

Conducting: two perspectives

Implementer's view

- Plan interviews from leadership to owners
- Ask open questions and ask to be shown
- Record facts before rating

Auditor's view

- Later uses the same discipline, with independence
- Never rates from a description alone
- Follows evidence trails across functions

LESSON 5.3 · RECAP

Lesson 5.3 recap

- Five steps: scope, plan, collect, rate, report
- Three sources of evidence, compared
- Open questions, and ask to be shown
- Record facts; the rating follows the record

Check your understanding

An interviewer asks: “Do you review access rights regularly?” The manager answers “Yes.” What should the interviewer do next?

A. Ask to see the last review and what changed because of it

B. Rate the item Comply and move on

C. Rate it Not implemented, since no evidence was offered

D. Ask the same question to a second manager

Check your understanding

An interviewer asks: “Do you review access rights regularly?” The manager answers “Yes.” What should the interviewer do next?

A **Ask to see the last review and what changed because of it**

B Rate the item Comply and move on

C Rate it Not implemented, since no evidence was offered

D Ask the same question to a second manager

Answer: A

A yes to a closed question is a description, not evidence. Asking to see the last review turns it into evidence the rating can rest on.

MSM ACADEMY

SECTION 5 · LESSON 5.4

The MSM gap analysis tool

5.4

Gap Analysis Tool v2.0

LESSON 5.4

What is in the tool

Sheet	What it does
Rating criteria	Defines Comply, Partially implemented and Not implemented
Checklist	208 questions: 115 on Clauses 4–10, 93 on Annex A
Implementation plan	Builds itself from the checklist; you add owners, dates and progress
Sub-clause and main-clause progress	Roll progress up automatically
Progress charts	Show status for the steering group
Transition	Historical only: not used in a new implementation

LESSON 5.4

The checklist

Ref	Question	Rating	Evidence or cause
Q5-4.3	Has the organization determined the scope of the ISMS?	Partially implemented	Draft scope; interfaces not identified
Q55-6.3	Are changes to the ISMS carried out in a planned manner?	Not implemented	No change planning exists
Q187-A.8.13	Are backups taken regularly, tested and stored securely?	Comply	Logs and a recorded restore test

LESSON 5.4

Rating criteria

Rating	Means	Typical evidence picture
Comply	Implemented and working	Evidence of practice, plus documented information where required
Partially implemented	Some implementation, incomplete	Practice without required documents, documents not followed, or part of the requirement only
Not implemented	No implementation	No evidence the requirement is met

LESSON 5.4

Worked example: clause 7.4

What you find	Rating	Why
Needs determined: what, when, with whom, how; practice matches	Comply	7.4 asks for communication needs to be determined
Regular security emails, but no one has decided what must be communicated, when or to whom	Partially implemented	Practice exists; the determination is missing
No communication about information security at all	Not implemented	No evidence of determining or communicating

LESSON 5.4

Clauses and Annex A in the checklist

Two kinds of question

- Clause questions: always applicable; none can be excluded
- Annex A questions: one per control, to support the later SoA decisions
- A control not yet known to be needed is still assessed, then decided in Section 6

LESSON 5.4

Filling in the checklist

Four rules

1. Rate every question; never leave a row blank
2. Comply needs objective evidence recorded
3. The other two ratings need a cause and a proposed remedial action
4. Rate the requirement, not how much you like the documents

The tool: two perspectives

Implementer's view

- Treat questions as prompts, not requirements
- Keep ratings consistent across assessors
- Record evidence so ratings can be checked

Auditor's view

- Ratings must trace to evidence
- A tool rating is not an audit conclusion
- Look for the requirement behind the question

LESSON 5.4 · RECAP

Lesson 5.4 recap

- Seven sheets; Transition is historical
- 208 questions: 115 on clauses, 93 on Annex A
- Three ratings defined by evidence; a document alone is never Comply
- Rate against what the clause actually asks

Check your understanding

An organization has an approved access control policy, but interviews and samples show it is not followed. How should the related question be rated?

A Comply: the policy exists and is approved

B Not implemented: the policy is ignored

C Partially implemented: documented, but not consistently applied

D Leave it blank until an internal audit

Check your understanding

An organization has an approved access control policy, but interviews and samples show it is not followed. How should the related question be rated?

A. Comply: the policy exists and is approved

B. Not implemented: the policy is ignored

C. **Partially implemented: documented, but not consistently applied**

D. Leave it blank until an internal audit

Answer: C

Documented information exists, but evidence shows it is not consistently applied. That is the definition of Partially implemented.

MSM ACADEMY

SECTION 5 · LESSON 5.5

From findings to an implementation plan

5.5

Remedial action, owners and dates

LESSON 5.5

Writing a gap description

Specific and factual

- The requirement: what the standard asks
- What was found, with the evidence
- What is missing, in one sentence

LESSON 5.5

Remedial action, not corrective action

Use the right term

- Remedial actions build what is missing in a system under construction
- Corrective action (10.2) removes the causes of nonconformities in an operating ISMS
- Same discipline, different place in the management system

LESSON 5.5

The implementation plan sheet

Column	What goes in it
Gap and rating	Pulled from the checklist automatically
Remedial action	Pulled from the checklist; refined if needed
Owner and resources	The accountable person, and what they need
Deliverables	What will exist when the action is done
Dates, progress, status	Planned start and finish, % complete, status

LESSON 5.5

Prioritizing actions

Dependencies first, then risk

- Foundations first: scope, context, risk method, governance
- Then what the risk treatment plan says matters most
- Quick wins where they cost little; never documents for show

LESSON 5.5 · EXERCISE

Exercise: rate and plan

A 60-person logistics company:

1 An approved security policy exists; four staff interviewed had never seen it.
2 No list of interested parties or their requirements: “we know our customers”.
3 Backups run nightly; last month’s restore test is recorded.
4 Internal audit is “planned for next year”; there is no programme.

Rate all four. Then write the gap description and a remedial action, with owner and date, for item 1.



Pause the video

Then compare with the model answer.

Model answer: rate and plan

Ratings	1 Partially implemented · 2 Not implemented · 3 Comply · 4 Not implemented
Gap (item 1)	5.2 f) requires the policy to be communicated; it is approved, but no staff interviewed knew it; communication is missing
Action (item 1)	Brief all staff and record acknowledgement · owner: Operations Manager · by end of next quarter

Each rating follows from evidence; each action has an owner, a deliverable and a date.

Planning: two perspectives

Implementer's view

- Write gaps that can be closed
- Use remedial actions with owners and dates
- Put foundations before documents

Auditor's view

- Later checks the plan was carried out (8.3)
- Looks for actions that changed practice
- Asks why priorities were set as they were

LESSON 5.5 · RECAP

Lesson 5.5 recap

- Gap = requirement, what was found, what is missing
- Remedial action for gaps; corrective action for nonconformities
- The plan sheet builds itself; add owners, deliverables and dates
- Foundations first, then risk-driven priorities

Check your understanding

A project plan closes 40 easy documentation gaps in month one, but the risk method is still undefined in month three. What is the main problem?

A None: visible progress keeps the sponsor engaged

B Priorities ignore dependencies; the risk method should come first

C Only that the documents were written too quickly

D The plan should have closed 60 gaps instead

Check your understanding

A project plan closes 40 easy documentation gaps in month one, but the risk method is still undefined in month three. What is the main problem?

A. None: visible progress keeps the sponsor engaged

B. Priorities ignore dependencies; the risk method should come first

C. Only that the documents were written too quickly

D. The plan should have closed 60 gaps instead

Answer: B

Many actions depend on the risk method, including which controls and documents are needed. Leaving it undefined while producing documents reverses the dependency.

MSM ACADEMY

SECTION 5 · LESSON 5.6

Tracking progress

From plan to steering group

5.6

LESSON 5.6

Sub-clause and main-clause progress

Sheet	How it works
Sub-clause progress	Looks up each sub-clause row in the plan and shows its planned finish, progress and status
Main-clause progress	Averages progress across each clause’s sub-clauses, and across the four Annex A themes
Status	Not started, on track, delayed or completed, from the plan

LESSON 5.6

Progress charts

Reporting to the steering group

- A sub-clause chart and a main-clause chart, updated from the roll-ups
- Show where progress is slow, not only how much is done
- Report trend over time, not a single snapshot before audits

LESSON 5.6

Common pitfalls

What makes a gap analysis misleading

- Ratings without recorded evidence
- Actions without owners or dates
- Treating the checklist as the requirement
- Never repeating the analysis after major change

LESSON 5.6 · RECAP

Lesson 5.6 recap

- Roll-ups calculate progress from the plan automatically
- Charts show where progress is slow
- Report trends to the steering group
- Avoid ratings without evidence and actions without owners

Check your understanding

The main-clause chart shows Clause 6 at 90% complete, but owners have not updated the plan for two months. What is the right conclusion?

A The chart may be out of date: roll-ups are only as current as the plan

B Clause 6 is nearly complete

C The tool has calculated the progress incorrectly

D The chart should be removed from steering reports

Check your understanding

The main-clause chart shows Clause 6 at 90% complete, but owners have not updated the plan for two months. What is the right conclusion?

- **A** **The chart may be out of date: roll-ups are only as current as the plan**
- **B** Clause 6 is nearly complete
- **C** The tool has calculated the progress incorrectly
- **D** The chart should be removed from steering reports

Answer: A

Roll-ups calculate from what owners enter in the plan. If the plan is stale, the chart is stale, whatever it shows.

SECTION 5 · SUMMARY

Gap analysis in one view

- Plan and collect evidence; ask to be shown
- Rate by evidence: Comply, Partially implemented, Not implemented
- Turn gaps into owned remedial actions with dates
- Track progress and report trends

SECTION 5 COMPLETE

Next: Section 6

Risk assessment, treatment and the SoA

